Semillero de Investigación

Pohlman Cuartas

David Steven Ospina Morales

Fundación Universitaria Área Andina

Facultad De Ingeniería

Docente, Raul Bareño Gutiérrez

Bogotá D.C

Marzo 2026

HU 05 : Seguridad privacidad y cumplimiento ley 1581 del 2012

Requisitos para el Tratamiento de Datos Personales en Colombia

Ley 1581 de 2012 y Lineamientos de la Superintendencia de Industria y Comercio (SIC)

La ley 1581 tiene como objetivo exponer los principales requisitos legales para el tratamiento de datos personales en Colombia, conforme a lo establecido y las directrices emitidas por la Superintendencia de Industria y Comercio (SIC), quien es el organismo encargado de la protección de datos personales en el país.

El tratamiento de datos personales en Colombia se rige principalmente por:

- Ley 1581 de 2012
- Decreto 1377 de 2013
- Decreto 1074 de 2015

Estas normas establecen los principios, derechos y obligaciones aplicables a las organizaciones que recolectan, almacenan, usan o circulan datos personales.

REQUISITOS PARA EL TRATAMIENTO DE DATOS PERSONALES

1 Autorización del titular

Las organizaciones deben obtener la autorización previa, expresa e informada por el titular de los datos personales antes de realizar cualquier tratamiento. Esta autorización puede obtenerse por medios físicos, electrónicos o verbales, siempre que sea verificable.

2 Política de tratamiento de datos personales

Toda entidad debe contar con una política de tratamiento de datos personales documentada, la cual debe incluir:

- Finalidades del tratamiento
- Derechos de los titulares
- Procedimientos para consultas y reclamos
- Datos de contacto del responsable del tratamiento

3 Finalidad del tratamiento

Los datos personales deben ser utilizados únicamente para las finalidades previamente informadas al titular. Cualquier uso distinto requiere una nueva autorización.

4 Seguridad de la información

Se deben implementar medidas de seguridad técnicas, administrativas y físicas para proteger los datos personales contra pérdida, uso indebido, acceso no autorizado o fraude.

5 Derechos de los titulares

Los responsables del tratamiento deben garantizar el ejercicio de los siguientes derechos:

- Conocer, actualizar y rectificar sus datos
- Solicitar prueba de la autorización
- Ser informado sobre el uso de sus datos
- Revocar la autorización y/o solicitar la supresión
- Presentar quejas ante la SIC

6 Registro Nacional de Bases de Datos (RNBD)

Las organizaciones obligadas deben registrar sus bases de datos en el Registro Nacional de Bases de Datos administrado por la SIC, cumpliendo con los requisitos establecidos.

7 Deberes de los responsables y encargados

Entre las principales obligaciones se encuentran:

- Garantizar la confidencialidad de la información
- Actualizar y rectificar los datos cuando sea necesario
- Tramitar consultas y reclamos
- Informar incidentes de seguridad

8 Procedimiento de consultas y reclamos

Las organizaciones deben establecer procedimientos internos para la atención de solicitudes:

- **Consultas**: máximo 10 días hábiles
- **Reclamos**: máximo 15 días hábiles

9 Tratamiento de datos sensibles

El tratamiento de datos sensibles está sujeto a condiciones especiales:

- Requiere autorización explícita
- Debe informarse al titular que no está obligado a suministrarlos
- Se consideran datos sensibles aquellos relacionados con salud, orientación política, datos biométricos, entre otros.

10 Tratamiento de datos de menores de edad

El tratamiento de datos de niños, niñas y adolescentes está permitido únicamente cuando:

- Se respete su interés superior
- Se cuente con autorización del representante legal

11 SANCIONES POR INCUMPLIMIENTO

El incumplimiento de las disposiciones legales puede acarrear sanciones impuestas por la SIC, tales como:

- Multas de hasta 2.000 salarios mínimos legales mensuales vigentes
- Suspensión de actividades relacionadas con el tratamiento de datos
- Cierre temporal o definitivo de operaciones

Fuentes: Ley 1581 de 2012 - Gestor Normativo - Función Pública

LEY ESTATUTARIA 1581 DE 2012 | Normatividad AGN

Ley 1581 de 2012 - Gestor Normativo - Función Pública

Los datos de las APIS se usan para entrenar modelos externos?

Generalmente y por defecto los datos de las APIs no se utilizan para el entrenamiento de modelos externos ni internos, a menos que el cliente lo permita, ya que los datos y la informacion son personales.

La infomacion o datos no seran enviados a ninguna compañia para el entrenamiento de modelos

Existen ocasiones que si lo permiten de manera temporal como son: para la deteccion de abuso o uso indebido, monitoreo de la seguridad y para el cumplimiento de requisitos legales.

Diseño de mecanismo de consentimiento informado

Este mecanismo se basa en la ley 1581 de 2012 en Colombia y se compone de 4 elementos fundamentales:

1. Aviso de privacidad: Deben recolipar la siguiente informacion

- Nombre
- Correo
- Mensajes ingresados por el usuario
- Datos cargados en los archivos
- Datos generados por el sistema

Consentimiento explicito: Debe ser siempre mostrado en un aviso para que el usuario pueda aceptar su uso.

- [ ] He leido y acepto el aviso de privacidad
- [ ] Autorizo el tratamiento de mis datos personales
- [boton para aceptar y continuar]

2. Registro del consentimiento: Siempre se debe guardar evidencia para evitar sanciones legales, esta información debe contener:

- User id
- Fecha
- Ip
- versión del aviso
- Consentimiento

Ejemplo:

```
{user_id: 12345,

timestamp: 2026-03-21T10:32:11

ip: 181.45.XX.XX,

privacy_version: v1.2,

consent_given: true}
```

3. **Control de retiro del consentimiento:** este siempre debe existir y debe contener botón en el perfil

```
[Eliminar mis datos]

[Revocar consentimiento]
```

Arquitectura técnica completa

Tabla:

```
consents

---------

id

user_id

timestamp

ip

version

status
```

Frontend:

- modal de privacidad
- checkbox obligatorio
- enlace a aviso completo

Implementación de SSL/TLS y Seguridad en el Servidor VPS

Para garantizar que los datos de los usuarios (archivos CSV/Excel) viajen de forma segura y el servidor sea seguro se deben aplicar las configuraciones.

A. Implementación de SSL/TLS (Cifrado en Tránsito)

Dado que el sistema utiliza un flujo conversacional y carga de archivos, el cifrado es obligatorio.

- **Herramienta Certbot (Let's Encrypt):** Certificados Proporcionados gratuitos, reconocidos por todos los navegadores y con renovación automática.
  https://certbot.eff.org/pages/about
- **Configuración de Proxy Inverso:** Se recomienda usar Nginx frente a la aplicación (Django o Node.js). Nginx gestionará la terminación SSL, liberando de carga al servidor de aplicaciones.
  https://www.f5.com/glossary/nginx
- **Protocolos**: Desactivar TLS 1.0 y 1.1; Permitir solo TLS 1.2 y 1.3.
- **HSTS (HTTP Strict Transport Security):** Configurar Nginx para forzar siempre el uso de HTTPS, evitando ataques de degradación.

B. Seguridad del Servidor (Lista de verificación de endurecimiento)

Se deben aplicar estas medidas:

- **Acceso SSH Seguro:**

  Deshabilitar el inicio de sesión como root.

  Cambiar el puerto por defecto (**22**) a uno personalizado (ej. 2234).

  Usar exclusivamente llaves SSH (**RSA 4096 bits**); prohibir contraseñas**.**

- **Firewall (UFW/iptables):**

  Cerrar todos los puertos excepto: 80 (HTTP - para redirección), 443 (HTTPS) y el puerto SSH personalizado.

  Actualizaciones Automáticas: Configurar actualizaciones desatendidas para parches críticos de seguridad del SO.

Política de Borrado Automático de Archivos Temporales

Esta política es vital para cumplir con el Principio de Finalidad y Veracidad de la Ley 1581 de 2012 de Colombia, asegurando que los datos sensibles no permanecerán en el servidor más tiempo del estrictamente necesario.

Definición de política

Objetivo: Eliminar cualquier rastro de datos personales o archivos subidos una vez finalizado el proceso de ETL y visualización.

Tipos de archivos: Archivos .csv, .xlsx, archivos temporales de procesamiento de Python (.tmp, .pyc) y fragmentos de datos enviados a la API.

Reglas de Ejecución

Borrado Inmediato: Una vez que el reporte final o el tablero se genera y el usuario cierra la sesión o transcurren 60 minutos de inactividad, el sistema debe activar un disparador de borrado.

Borrado por Antigüedad: Se establecerá una tarea programada en el servidor que se ejecutará cada hora:

- **Regla:** Eliminar cualquier archivo en la carpeta /tmp/uploads/ cuya fecha de creación sea superior a 2 horas.

Cumplimiento de la Ley 1581

Privacidad por diseño: El sistema no almacenará bases de datos permanentes con la información cargada.

Trazabilidad: Se mantendrá un registro de cuándo se borró el archivo (sin guardar el contenido del archivo) para demostrar ante la SIC (Superintendencia de Industria y Comercio) que se cumple con la supresión de datos.